

Security+ 3.2 · Port Security

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 3.2 — Port Security (3:50)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: 802.1X: autentica o USUÁRIO/máquina antes de dar acesso à rede via switch. RADIUS centraliza o AAA. Sem 802.1X, qualquer um conecta e tem acesso. NAC (Network Access Control) = 802.1X + postura (antivirus/patch health).

Highlights que a prova cobra

- 802.1X: autentica ANTES de dar acesso à porta do switch
- RADIUS: o backend central de AAA
- NAC: 802.1X + checagem de saúde (antivirus, patch)

Dicas de prova & Cenários Típicos

- 'requires authentication before network access'=802.1X

Cenário clássico de exame: 'switch requires login before allowing traffic'=802.1X + RADIUS.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 3.2 — Port Security)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **TACACS+:** Terminal Access Controller Access-Control System Plus: Protocolo AAA corporativo que opera sobre TCP porta 49, cifra o pacote inteiro e separa autenticação de autorização, permitindo controle comando a comando em roteadores e switches.
- **RADIUS:** Remote Authentication Dial-In User Service: Protocolo AAA cliente-servidor (UDP 1812/1813) amplamente usado em redes 802.1X e VPNs; criptografa apenas o campo da senha e combina autenticação com autorização.
- **802.1X:** Padrão IEEE de controle de acesso a portas de rede (Port-Based Network Access Control - PNAC). Bloqueia a porta física ou o canal Wi-Fi até que o usuário/dispositivo apresente credenciais válidas validadas via RADIUS.
- **KERBEROS:** Protocolo de autenticação padrão do Active Directory baseado em tickets criptografados emitidos pelo KDC (Key Distribution Center: AS e TGS), prevenindo senhas em texto claro na rede.
- **LDAP:** Lightweight Directory Access Protocol: Protocolo de consulta a árvores de diretório (porta TCP 389 em texto claro).

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Serviço que centraliza a autenticação de acesso à rede (login em switch/VPN via servidor central):

- A) RADIUS**
- B) DNS**
- C) SMTP**
- D) NTP**

2. Gerencia serviços (start/stop/status) no Linux moderno:

- A) systemctl**
- B) service (antigo)**
- C) initd**
- D) runlevel**

3. Qual protocolo de autenticação utiliza tickets e é amplamente usado em ambientes Active Directory?

- A) RADIUS**
- B) TACACS+**
- C) Kerberos**
- D) LDAP**

4. Cenário corporativo (Port Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: '802.1X: autentica ANTES de dar acesso à porta do switch'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Implementar a solução correspondente: 802.1X: autentica ANTES de dar acesso à porta do switch...**
- B) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- C) Substituir controles técnicos preventivos por termos de adesão informais**
- D) Permitir acesso compartilhado entre administradores com credenciais genéricas**

5. Cenário corporativo (Port Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'RADIUS: o backend central de AAA'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: RADIUS: o backend central de AAA...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Port Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'NAC: 802.1X + checagem de saúde (antivirus, patch)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: NAC: 802.1X + checagem de saúde (antivirus, patch)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Port Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: '"requires authentication before network access'=802.1X'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'requires authentication before network access'=802.1X...

8. Cenário corporativo (Port Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'switch requires login before allowing traffic'=802.1X + RADIUS.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'switch requires login before allowing traffic'=802.1X + RADIUS....
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Port Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: '802.1X: autentica ANTES de dar acesso à porta do switch'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 802.1X: autentica ANTES de dar acesso à porta do switch...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Port Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'RADIUS: o backend central de AAA'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: RADIUS: o backend central de AAA...

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) A — RADIUS.

✓ **Por que está certa:** O RADIUS (Remote Authentication Dial-In User Service) é um protocolo de autenticação, autorização e accounting (AAA) que centraliza o controle de acesso à rede.

Dispositivos de acesso como switches, roteadores, VPNs e pontos de acesso wireless atuam como clientes RADIUS e encaminham as credenciais dos usuários para um servidor RADIUS central. Este servidor verifica as credenciais contra um diretório (ex.: Active Directory, LDAP) e retorna uma decisão de aceitação ou rejeição, além de atributos de autorização (ex.: VLAN, tempo de sessão). Isso permite gerenciar políticas de acesso de forma consistente em toda a infraestrutura, sem configurar contas locais em cada dispositivo.

✗ **Por que as outras estão erradas:**

- **DNS:** O DNS (Domain Name System) é um serviço de resolução de nomes que traduz nomes de domínio legíveis por humanos (ex.: `www.exemplo.com`) em endereços IP. Ele não autentica usuários, não gerencia sessões de acesso e não centraliza credenciais. Embora exista DNSSEC para autenticar respostas DNS, isso é uma segurança do próprio protocolo, não um mecanismo de autenticação de acesso à rede para usuários ou dispositivos. Portanto, DNS não atende ao requisito de centralizar login em switches ou VPNs.
- **SMTP:** O SMTP (Simple Mail Transfer Protocol) é o protocolo padrão para envio e transferência de mensagens de e-mail entre servidores. Ele lida com comunicação assíncrona de correio eletrônico, não com autenticação de acesso à rede. Embora exista autenticação SMTP (SMTP AUTH) para envio de e-mails, ela se aplica ao próprio serviço de e-mail, não ao controle de acesso a switches, VPNs ou outros equipamentos de rede. Portanto, é totalmente inaplicável ao cenário descrito.
- **NTP:** O NTP (Network Time Protocol) é usado para sincronizar os relógios de dispositivos em rede com uma fonte de tempo confiável. A sincronização precisa é importante para logs forenses, validade de certificados e protocolos de autenticação baseados em tempo (como Kerberos), mas o NTP em si não autentica usuários nem centraliza o acesso à rede. Ele não recebe credenciais, não consulta diretórios e não toma decisões de autorização. Portanto, não substitui um servidor RADIUS.

2) A — systemctl.

✓ **Por que está certa:** `systemctl` é o comando principal do `systemd`, o sistema de inicialização e gerenciamento de serviços padrão na maioria das distribuições Linux modernas (RHEL 7+, Ubuntu 15.04+, Debian 8+, CentOS 7+, etc.). Ele permite iniciar (`start`), parar (`stop`), reiniciar (`restart`), recarregar (`reload`), habilitar (`enable`), desabilitar (`disable`) e verificar o status (`status`) de unidades de serviço, soquetes, dispositivos e pontos de montagem. A questão pede o gerenciador de serviços no Linux moderno, e `systemctl` é a ferramenta canônica do `systemd` para essa função, sendo o padrão de facto na indústria.

✗ **Por que as outras estão erradas:**

- **service (antigo):** O comando `service` é um wrapper legado do SysVinit que ainda existe em alguns sistemas por compatibilidade, mas não é o gerenciador nativo do Linux moderno. Ele executa scripts de inicialização em `/etc/init.d/` e não oferece recursos como dependências explícitas, ativação por soquete, `cgroups` ou `journaling` de logs. Em distribuições modernas, o `service` geralmente redireciona para `systemctl`, mas por si só não representa a ferramenta atual de gerenciamento de serviços. A questão pede o gerenciador no Linux moderno, e o `service` é considerado obsoleto para essa finalidade.
- **initd:** `initd` (ou SysVinit) é o sistema de inicialização tradicional baseado em scripts sequenciais localizados em `/etc/init.d/` e níveis de execução (`runlevels`). Ele foi amplamente substituído pelo

systemd por ser mais lento, não gerenciar dependências de forma eficiente e não oferecer recursos como paralelização, controle de recursos ou logs centralizados. Não é um comando de gerenciamento de serviços no Linux moderno, mas sim o próprio sistema de init antigo. A questão pede a ferramenta de gerenciamento, e initd não é um comando, mas sim a arquitetura legada.

- **runlevel:** runlevel é um conceito do SysVinit que define o estado operacional do sistema (ex.: 0 = desligado, 1 = monousuário, 3 = multiusuário com rede, 5 = gráfico). O comando runlevel exibe o nível de execução anterior e atual, mas não gerencia serviços individuais (start/stop/status). Ele é um resquício do modelo antigo e não oferece controle granular sobre unidades de serviço. Portanto, não atende ao requisito de gerenciar serviços no Linux moderno, sendo apenas um utilitário informativo do sistema legado.

3) C — Kerberos.

✓ **Por que está certa:** O **Kerberos** é um protocolo de autenticação baseado em tickets, amplamente utilizado em ambientes Active Directory (AD) da Microsoft. Ele utiliza criptografia simétrica e um Centro de Distribuição de Chaves (KDC) para autenticar usuários e serviços sem transmitir senhas pela rede. O processo envolve a obtenção de um Ticket Granting Ticket (TGT) e, posteriormente, tickets de serviço para acessar recursos. No syllabus da CompTIA Security+ (SY0-701), Kerberos é destacado como o protocolo de autenticação padrão em domínios Windows, oferecendo autenticação mútua e suporte a single sign-on (SSO). A menção a 'tickets' e 'Active Directory' aponta diretamente para Kerberos.

✗ **Por que as outras estão erradas:**

- **RADIUS:** RADIUS (Remote Authentication Dial-In User Service) é um protocolo de autenticação, autorização e contabilização (AAA) usado principalmente para acesso remoto a redes, como VPNs, Wi-Fi corporativo e conexões dial-up. Ele não utiliza tickets; em vez disso, emprega um modelo cliente-servidor com atributos e desafios (como PAP, CHAP, EAP). Embora possa integrar-se ao Active Directory para validar credenciais, não é o protocolo nativo de autenticação do AD e não se baseia em tickets. Portanto, não corresponde à descrição.

- **TACACS+:** TACACS+ (Terminal Access Controller Access-Control System Plus) é um protocolo AAA desenvolvido pela Cisco, usado para autenticação, autorização e accounting de dispositivos de rede (roteadores, switches). Ele separa as funções AAA e criptografa todo o payload, mas não utiliza tickets e não é o mecanismo de autenticação padrão do Active Directory. Seu foco é o gerenciamento de acesso a equipamentos de infraestrutura, não a autenticação de usuários em domínios Windows. Logo, está incorreto para o contexto apresentado.

- **LDAP:** LDAP (Lightweight Directory Access Protocol) é um protocolo de acesso a serviços de diretório, como o Active Directory, permitindo consultas e modificações em objetos (usuários, grupos, computadores). Ele é usado para leitura e escrita no diretório, mas não é um protocolo de autenticação baseado em tickets. A autenticação no AD geralmente ocorre via Kerberos ou NTLM; o LDAP pode ser usado para autenticação simples (bind), mas não emprega tickets e não é o mecanismo principal de autenticação em ambientes AD. Portanto, não atende à descrição de 'utiliza tickets'.

4) A — Implementar a solução correspondente: 802.1X: autentica ANTES de dar acesso à porta do switch....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Port Security): 802.1X: autentica ANTES de dar acesso à porta do switch.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) C — Implementar a solução correspondente: RADIUS: o backend central de AAA....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Port Security): RADIUS: o backend central de AAA.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) A — Implementar a solução correspondente: NAC: 802.1X + checagem de saúde (antivirus, patch)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Port Security): NAC: 802.1X + checagem de saúde (antivirus, patch).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) D — Implementar a solução correspondente: 'requires authentication before network access'=802.1X....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Port Security): 'requires authentication before network access'=802.1X.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) B — Implementar a solução correspondente: 'switch requires login before allowing traffic'=802.1X + RADIUS.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Port Security): 'switch requires login before allowing traffic'=802.1X + RADIUS..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) B — Implementar a solução correspondente: 802.1X: autentica ANTES de dar acesso à porta do switch....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Port Security): 802.1X: autentica ANTES de dar acesso à porta do switch.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) D — Implementar a solução correspondente: RADIUS: o backend central de AAA....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Port Security): RADIUS: o backend central de AAA.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

